MyPowerPlant — Security Plan Implementation

Progress report: reconciling the `sec` branch and implementing Iteration 2 security controls

Prepared for Vimal · 2026-09-16 · Branch: `sec` (local, not yet pushed)

---

1. Starting point

The task was to implement the Iteration 2 Security Plan, starting from Epic 3 (VPP recommendation), which a teammate said was already implemented. The plan called for branching from `main`.

Investigation found that the existing `sec` branch — the branch meant to hold this security work — was **64 commits behind** `main` and predated Epic 3 entirely. It also predated a significant architecture change: `main` had since removed server-side household-profile persistence (`POST /api/profile`, `household_id` records) in favour of storing the profile only in the browser, matching the plan's own stated privacy posture.

At the same time, `sec` contained substantial security work `main` never received: a `security.yml` CI workflow (secret scanning, dependency audit, lint, tests), `dependabot.yml`, backend/frontend test suites, and the full `testing/` QA documentation set.

Decision, confirmed with you: merge `main` into `sec`, adopt `main`'s current architecture, and port `sec`'s CI/test assets forward — rewriting anything that no longer matched the current app rather than leaving it broken.

2. R20 — Provider-domain allow-list DONE

Security Plan R20 (High priority, "required before Epic 3 launch") requires outbound VPP provider links to be checked against a hardcoded domain allow-list before being rendered as clickable — not trusted directly from data.

Finding: the "Learn more" dialog in `VppSuggestions.tsx` rendered `plan.href` — sourced from the `vpp_suggestion_plans` database table — straight into an `<a href>` with no validation, using `rel="noreferrer"` only.

Fix (commit `f2b4b52`):

- Added `safeProviderUrl()` in `vppSuggestions.ts` — a hardcoded allow-list of the 5 seeded provider domains (agl.com.au, originenergy.com.au, engie.com.au, diamondenergy.com.au, globirdenergy.com.au). Requires `https:` and an exact-or-subdomain hostname match.
- `VppSuggestions.tsx` now only renders a clickable link when the href passes that check; otherwise shows plain text ("We couldn't verify this provider's link…") — matching the plan's "not rendered as a clickable link" requirement.
- Tightened `rel="noreferrer"` to `rel="noopener noreferrer"`.
- Added self-test assertions covering: allow-listed host accepted, non-allow-listed host rejected, lookalike domains (`not-agl.com.au`) rejected, allow-listed domain used as a subdomain of an attacker host rejected, non-https rejected, `javascript:` URLs rejected, malformed URLs handled without throwing.

Also verified R21 (source + last-verified dates, staleness flag, "not disclosed" for missing terms) and R24 (privacy claim) were already satisfied by the existing Epic 3 code — the VPP matching runs entirely client-side against the public `GET /api/methodology` reference data, and the household profile is never sent to the server.

3. Merging `main` into `sec` DONE

Merge commit `ec6c8f8`. Seven files conflicted; all resolved in favour of `main`'s architecture, verified byte-identical to `main` afterward:

File	Resolution
`backend/app/main.py`	Took main's version — methodology router, middleware-based rate limiter, GET/HEAD-only CORS
`backend/app/models.py`	Took main's version — no household_profiles/submissions ORM models
`backend/app/rate_limit.py`	Took main's sliding-window `RateLimitMiddleware` over sec's slowapi-based limiter
`backend/app/routes/profile.py`	Deleted (main removed the whole write endpoint)
`frontend/src/lib/householdId.ts`	Deleted (no more server-issued household identifier)
`frontend/src/lib/profileApi.ts`	Deleted (no server calls for the profile anymore)
`frontend/src/lib/profileStorage.ts`	Took main's version — sanitized, browser-only, no server sync

Also removed the now-unused `slowapi` dependency from `backend/requirements.txt`.

Ported forward from sec (no conflicts — main never had these): `.github/workflows/security.yml`, `.github/dependabot.yml`, the full `testing/` QA documentation folder, and the backend/frontend test suites (rewritten — see next section).

4. Rewriting the security test suites DONE

Commit `5283553`. The test suites sec carried were built entirely around the now-removed profile-persistence API and failed to compile or run after the merge. Each was reconciled against the current app rather than patched superficially — verified empirically against the running app in every case, not guessed.

backend/tests/test_access_control.py

Old suite tested IDOR protection on `household_id` records (S6.1) — that whole resource family is gone. Replaced with tests pinning the invariant the old suite's intent maps to now: **no write-capable or record-addressed surface exists at all**. This doubles as a regression guard for R24 (the "we don't store your data" claim going silently false if persistence is ever reintroduced).

- `POST /api/profile` → 404 (route doesn't exist)
- No `household_id`-addressed endpoint exists (GET/PUT/PATCH/DELETE all 404)
- Write methods (POST/PUT/PATCH/DELETE) on the two real routes → 405
- OpenAPI schema audit: every documented route exposes only GET/HEAD/OPTIONS

backend/tests/test_input_validation.py

Old suite validated profile fields (postcode format, allow-lists, numeric bounds, control characters, oversized payloads) against the removed write endpoint. The two remaining routes take no body, query parameter, or path parameter — confirmed via the OpenAPI schema — so there is no user-controlled input left to validate. Replaced with: a schema check pinning "no input surface," plus garbage-input robustness checks (oversized query string, script tags, path traversal, SQL-injection-shaped paths, malformed JSON body on a GET route) confirming nothing crashes or leaks a traceback/internal path.

backend/tests/test_headers_and_limits.py

- Repointed from `/api/profile` to `/api/health` / `/api/methodology`
- Added explicit HSTS coverage: present when `X-Forwarded-Proto: https`, absent over plain HTTP — main's `SecurityHeadersMiddleware` only sets it conditionally, which the old suite didn't test
- Dropped "creation throttled harder than reads" — there's no write endpoint left to throttle harder than reads
- Rate-limit test now hits `/api/health` 80× and confirms a 429 appears (main's limiter: 60 requests/60s), plus checks the 429 carries `Retry-After`

frontend/src/lib/kpis.test.ts

The largest rewrite (93 tests). The old file imported hardcoded constants from a deleted `data/appliances.ts` and called `buildKpiReport(profile)` with one argument; the current signature is `buildKpiReport(profile, data)`, sourced from `GET /api/methodology` at runtime. Rewired to build the same data from `methodologyFixture.ts` (mirrors the Alembic seed) — verified the numeric constants are identical to the deleted file before relying on it, so the hand-worked financial assertions didn't need to be re-derived.

Three real (non-mechanical) fixes, each verified by running the actual suite rather than assumed:

- **KPI-01 (refrigerator power) — already fixed upstream.** The old suite pinned a known defect: refrigerator power was 1.92 kW (same as the air conditioner, a rated input figure) × 168h/week = 322 kWh/week, ~30× too high. Main's methodology data now uses a duty-cycle-adjusted 0.057 kW. Converted the test from `it.fails` to a plain passing regression test and deleted the "pinned buggy behaviour" companion test.
- **Dryer hours.** Old test expected stated cycles to equal hours 1:1. Main's `dryerHoursPerWeek()` now multiplies cycles by a published per-cycle duration (~54 min, sourced from a Sustainability Victoria report) — a genuine accuracy improvement, not a regression. Updated the test to compute the expected value from that published figure.
- **`netEnergyValueAud` sign.** A "components must all be non-negative" test failed for high-consumption/no-solar profiles. This field is documented as `(generation − consumption) × rate` — legitimately negative for any household that imports more than it generates. Excluded it from the non-negative check rather than weakening the check generally.
- Timeframe tests updated from a since-removed `'monthly'` option to the current `'fortnightly'` option.

frontend/src/lib/validateProfile.test.ts

The usage step no longer validates `monthlyKwh` (it's optional now — an intentional product change from an earlier commit, not a bug). Removed the VAL-08 boundary-test block for that field and adjusted the "reports every blank field at once" count from 5 to 4 to match.

> **Verification:** 32/32 backend tests pass (`pytest tests/ -q`), 170/170 frontend tests pass (`vitest run`), both dev-time self-test scripts pass, and `npm run build` / `tsc -b` are clean.

5. Current branch state

`sec` is 67 commits ahead of `origin/sec` (64 from the `main` merge + 2 authored here) and fully caught up with `main`. Nothing has been pushed.

```
f2b4b52  Gate VPP provider links behind a domain allow-list (R20)
5283553  Port sec's security test suites forward onto main's architecture
ec6c8f8  Merge remote-tracking branch 'origin/main' into sec
b56e171  (main, up to date)
```

6. Known open items NOT DONE

> **The ported `security.yml` CI workflow will fail on its first run.** It runs `npm run lint`, and there are 3 pre-existing lint errors already present on `main` (2 React "setState in effect" warnings in `VppSuggestions.tsx` / `SearchSelect.tsx`, 1 control-character regex rule in `profileStorage.ts`). These were not introduced by this work and were left alone as out of scope — but they will need fixing before the CI workflow can pass, since the workflow now exists where it didn't before.

Not yet addressed from the Iteration 2 plan (beyond confirming R21/R24 were already satisfied for Epic 3):

- **R22** — calendar/.ics and alert-field injection (Epic 4, discharge timing alerts) — Epic 4 status not yet checked
- **R17–R19** — microphone consent, voice data handling, transcription confirmation (Epic 5, voice questionnaire) — Epic 5 status not yet checked
- **R21** "two-person review on provider dataset changes" — a process control, not something enforceable in code (e.g. a CODEOWNERS rule could approximate it)
- Section 6 penetration-test items for Epic 3/4/5 — not run

7. Next step

Awaiting your go-ahead to push `sec` to `origin/sec`. Nothing has been pushed or shared beyond this local branch.
